DOCUMENTO INSTITUCIONAL

Plan de seguridad digital

IES Manuel de Falla

M stoles Comunidad de Madrid



CENTRO
IES Manuel de Falla
Centro p blico
Comunidad de Madrid

C DIGO OFICIAL
28028568

DIRECCI N
Avenida Ol mpica, 16
28935 M stoles (Madrid)

COORDINACI N TIC
Diego Navarro

Tel. 91 617 10 74 91 236 94 06

ies.manueldefalla.mostoles@educa.madrid.org

Contenido

Todas las entradas son enlaces: pulsa sobre una para ir al apartado.

R **Resumen**
Prioridades, hoja de ruta y decisiones que se piden a la direcci n.

1 **Finalidad, alcance y marco normativo**
Qu protege el plan, normativa de referencia y responsables.

2 **Situaci n tecnol gica y riesgos**
Plataformas del centro, mapa de riesgos y criterios de implantaci n.

3 **Identidades, sesiones y puestos**
Bloqueo, cuentas, MFA, privilegios y puestos compartidos.

4 **Datos, accesos y recuperaci n**
Clasificaci n, revisi n de accesos, copias y brechas.

5 **Red, dispositivos, correo y personas**
Segmentaci n, correo, m viles, IA generativa y formaci n.

6 **Incidentes y continuidad**
Procedimiento, gravedad, se uelos y continuidad.

7 **Plan de acci n**
Veintid s medidas con prioridad, responsable y plazo.

8 **Glosario, fuentes y aprobaci n**
Siglas, referencias consultadas, agradecimientos y firmas.

9 **Anexos**
Agenda de contactos, ficha de incidente, inventario y costes estimados.

R Resumen

Este plan re ne las medidas m nimas para proteger las cuentas, los datos del alumnado y la continuidad de la actividad del instituto. Est pensado para aplicarse por fases, con pilotos y sin depender de herramientas que el centro no tiene.

Cinco prioridades

1 Cuentas protegidas
MFA en direcci n y administraci n, bajas revisadas y cuentas nominales.

2 Copias que se restauran
Una copia verificada y una prueba de restauraci n cada trimestre.

3 Sesiones bloqueadas
Bloqueo autom tico en aulas y despachos, empezando por un piloto.

4 **Datos con acceso m nimo**
Carpetas por funci n, proveedores revisados y pol tica de IA generativa.

5 **Respuesta preparada**
Procedimiento, contactos y ficha de incidente impresos y a mano.

Hoja de ruta a seis meses

MES 1 Base y mayor riesgo	MESES 2 Y 3 Control de datos	MESES 4 A 6 Ampliaci n
Confirmar plataformas y administradores Inventario y revisi n de cuentas privilegiadas Primera copia verificada MFA en administraci n y direcci n Piloto de bloqueo autom tico Formaci n de inicio de curso	Permisos y carpetas por funci n Primera restauraci n completa Mapa de datos y proveedores Pol tica de IA generativa Dise o de la segmentaci n de red Primer simulacro de phishing	Bloqueo en todas las aulas Segmentaci n de red, si procede SPF, DKIM y DMARC MDM o EDR en equipos compatibles Llaves FIDO2 en cuentas cr ticas Ejercicio de incidente

El detalle de las veintid s medidas est en el apartado 7.

Decisiones que se piden a la direcci n

1. Aprobar el plan y el calendario propuesto.
2. Designar a los responsables que hoy figuran en blanco: direcci n, responsable del tratamiento y DPD, secretar a.
3. Autorizar los pilotos de bloqueo autom tico y de MFA.
4. Decidir el presupuesto de licencias, llaves de seguridad y almacenamiento externo, una vez calculado el coste con el diagn stico del mes 1 (estimaci n orientativa en el Anexo D).

1 Finalidad, alcance y marco normativo

1.1 Finalidad

Este plan establece medidas para proteger la informaci n del instituto, reducir los accesos indebidos y mantener la actividad educativa ante una p rdida, una cuenta comprometida, malware o ransomware. La actividad del centro depende de cuentas digitales, correo, plataformas educativas, equipos de aula, red y documentos compartidos: la protecci n debe impedir accesos accidentales, limitar el alcance de un fallo y permitir la recuperaci n.

1.2 Alcance

El plan cubre los datos de alumnado, familias y personal; calificaciones, ex menes, actas e informes de orientaci n; el correo y las cuentas administrativas; y los equipos de aula, port tiles y dispositivos conectados. Afecta a todo el personal del centro y a los servicios descritos en el apartado 2.

1.3 Marco normativo y documentos de referencia

RGPD y LOPDGDD	Reglamento (UE) 2016/679 y Ley Org nica 3/2018. Principios de tratamiento, seguridad de los datos personales y notificaci n de brechas.
Esquema Nacional de Seguridad	Real Decreto 311/2022. Se aplica a todo el sector p blico (art. 2) y EducaMadrid indica que lo sigue. La Consejer a, con el DPD, confirma qu sistemas del centro entran en su alcance.
Gu a para centros educativos (AEPD)	El RGPD no fija un cat logo de medidas: se eligen seg n el riesgo de cada tratamiento. La gu a figura como en revisi n ; conviene comprobar la versi n vigente.
DPD de la Consejer a de Educaci n	protecciondatos.educacion@madrid.org 91 720 4068. Consultas y brechas de datos personales; comprobar la p gina oficial antes de una comunicaci n formal.
INCIBE y CISA	Buenas pr cticas para centros educativos: bloqueo de sesi n, MFA, copias aisladas y probadas, plan de respuesta a incidentes y formaci n.
EducaMadrid	Publica principios de confidencialidad, integridad y disponibilidad. No sustituyen las medidas que el centro debe aplicar en sus propios equipos, sesiones, dispositivos y documentos.

1.4 Objetivos del curso

1. Reducir el riesgo de acceso a una sesi n abierta.
2. Limitar el efecto de una contrase a comprometida.
3. Recuperar la informaci n esencial despu s de una p rdida o un ransomware.
4. Mantener los accesos y tratamientos dentro de las funciones autorizadas.
5. Responder de forma ordenada y documentada a una incidencia.

1.5 Responsabilidades

Direcci n
Aprueba prioridades y comunicaci n.
Persona: _____

Coordinaci n TIC
Mantiene inventario, configuraciones y pruebas.
Persona: **Diego Navarro**

Responsable del tratamiento y DPD
Revisan privacidad, proveedores y brechas.
Persona: _____

Personal
Aplica la pol tica, bloquea equipos y reporta sospechas.
Persona: **Todo el personal**

2 Situaci n tecnol gica y riesgos

2.1 Plataformas del centro

Google Workspace
Classroom, correo @iesmanueldefalla.com y documentos compartidos.

POR CONFIRMAR
Qui n administra la consola, edici n contratada, unidades organizativas, MFA y llaves de seguridad.

EducaMadrid
Servicios auton micos. Cada alumno tiene su usuario y contrase a.

POR CONFIRMAR
Qu cuentas y soporte administra el centro; si admite MFA o FIDO2.

Equipos de aula y port tiles POR INVENTARIAR

Puestos del profesorado, aulas de inform tica y biblioteca.

POR CONFIRMAR

Parque real, sistema operativo y si existe GPO, MDM o EDR.

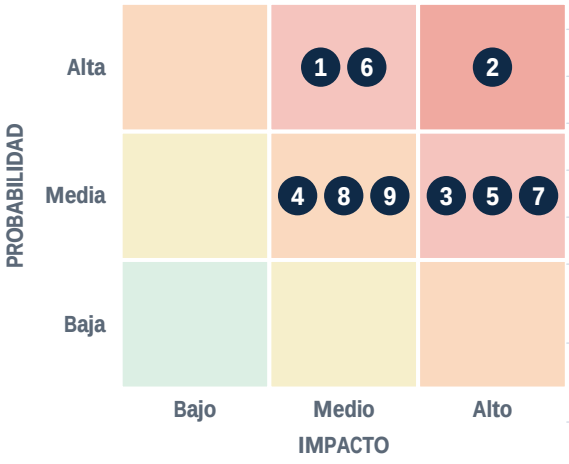
Red del centro

Wi-Fi y red cableada.

POR CONFIRMAR

Diagrama, equipos y qui n los administra.

2.2 Riesgos principales



Valoraci n orientativa propuesta; debe revisarse con la direcci n y el DPD.

N.	RIESGO	MEDIDAS
1	Sesi n abierta en un equipo compartido	3.1 3.5
2	Contrase a comprometida o phishing	3.3 5.2
3	Ransomware o p rdida de datos	4.4
4	Cuenta de personal de baja que sigue activa	3.2 4.2
5	Acceso excesivo a informes sensibles	4.1 4.2
6	Datos del alumnado en IA o nubes no autorizadas	5.4
7	Red plana: alumnado o invitados alcanzan sistemas de administraci n	5.1
8	P rdida de port til, m vil o USB	4.1 5.3 6.5
9	Ca da de Internet o de EducaMadrid	6.5

2.3 Criterios de implantaci n

Empezar con un aula piloto y documentar la configuraci n antes de extenderla.

Validar cada cambio con la coordinaci n TIC y, cuando afecte a datos personales, con el DPD.

Registrar responsables, fecha, alcance, incidencias y plan de reversi n.

Mantener una alternativa operativa ante la ca da de Internet y un contacto fuera de la red.

3 Identidades, sesiones y puestos

3.1 Bloqueo autom tico y cierre de sesi n

INCIBE recomienda bloquear los dispositivos cuando se dejan de usar, solicitar contrase a para continuar, cerrar sesi n en equipos compartidos y desactivar mantener sesi n iniciada y recordar contrase a .

Windows. La directiva *Interactive logon: Machine inactivity limit* se encuentra en Configuraci n del equipo > Configuraci n de Windows > Configuraci n de seguridad > Directivas locales > Opciones de seguridad. El valor se expresa en segundos (de 0 a 599.940) y se guarda como valor DWORD *InactivityTimeoutSecs* en *HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System*. Con 0 o sin valor la directiva queda desactivada. Microsoft aconseja ajustar el tiempo seg n el uso y la ubicaci n del equipo.

10 min
Aulas
Valor de la directiva: 600 segundos.

15 min
Despachos
Valor de la directiva: 900 segundos.

Son valores internos propuestos, no exigencias legales. La prueba debe comprobar que la pol tica se aplica, exige credencial y no es sustituida por otra GPO o MDM. El bloqueo conserva la sesi n: en puestos compartidos hay que decidir si hace falta cierre de sesi n completo, modo PC compartido o limpieza del perfil, y probar antes archivos abiertos, accesibilidad, presentaciones y recuperaci n.

Google Workspace. Google fija catorce d as como duraci n predeterminada de las sesiones web de sus servicios. Un administrador con el privilegio de ajustes de seguridad puede reducirla en la consola (en ingl s: Security > Access and data control > Google session control > Web session duration) y aplicar el cambio por unidad organizativa. Solo surte efecto cuando el usuario cierra sesi n y vuelve a iniciarla. No se aplica a las aplicaciones m viles nativas de Gmail y Calendar, a las aplicaciones OAuth ni a ChromeOS. Aplicar el cambio primero a una unidad organizativa piloto.

3.2 Cuentas y permisos

- Utilizar cuentas nominales; no compartir usuarios para notas, secretar a o administraci n.
- Separar la cuenta administrativa de la cuenta cotidiana.
- Desactivar o revisar de inmediato las cuentas del personal que cause baja.
- Aplicar las pol ticas por unidad organizativa en Google Workspace (alumnado, profesorado, equipo directivo, administraci n y servicios) para poder pilotar y establecer excepciones sin afectar a todo el centro.
- Alumnado: las credenciales de EducaMadrid son personales; no se comparten ni se guardan en equipos de aula. Se recomienda cambiar la contrase a inicial en el primer acceso, si el servicio lo permite.
- No reutilizar la contrase a del centro en servicios personales ni guardar contrase as en navegadores de equipos compartidos.
- Usar un canal alternativo para confirmar peticiones urgentes de direcci n o secretar a.

REFERENCIA: L NEA BASE DE CISA
CISA publica una l nea base de configuraci n segura para Google Workspace (proyecto SCuBA). Asume la edici n Enterprise Plus y puede no aplicarse a todas las ediciones: sala como gu a de qu revisar en la consola, no como lista obligatoria.

3.3 MFA y llaves FIDO2

Activar MFA primero en administradores, direcci n, correo, acceso remoto y cuentas con datos sensibles, si el servicio lo permite. Para direcci n, coordinaci n TIC y cuentas administrativas, priorizar la autenticaci n resistente al phishing mediante llaves FIDO2 o passkeys compatibles con el proveedor de identidad: la llave utiliza criptograf a vinculada al dominio leg timo y no entrega una contrase a reutilizable a una p gina falsa. En su ficha sobre MFA, CISA la presenta como la nica autenticaci n resistente al phishing de uso generalizado, e INCIBE recomienda activar al menos la verificaci n en dos pasos cuando sea posible.

- Empezar con dos cuentas administrativas y dos llaves por persona: una de uso y otra de custodia.
- Registrar la llave en la plataforma y anotar su n mero de inventario, sin guardar secretos privados.
- Probar la recuperaci n con la segunda llave y con una cuenta de emergencia.
- Revocar de inmediato una llave perdida y revisar las sesiones activas.

No comprar llaves antes de confirmar que Google Workspace (en la edici n contratada) o EducaMadrid admiten FIDO2/WebAuthn.

3.4 Privilegios de administraci n

La cuenta de administraci n no debe tener privilegios permanentes para el uso cotidiano. Se aplica una alternativa organizativa:

Cuenta administrativa separada de la cuenta de trabajo diario.

Autorizaci n previa de la coordinaci n TIC, contrase a custodiada y registro de cada intervenci n.

Cuenta de emergencia documentada y protegida, sin usarla para el trabajo diario.

No crear cuentas temporales sin saber c mo se revocar n.

3.5 Puestos compartidos y aula segura

Para aulas de inform tica, biblioteca y puestos utilizados por varios grupos, el modo *Shared PC* de Windows est dise ado para dispositivos multiusuario. Con la gesti n de cuentas activada elimina perfiles autom ticamente al cerrar sesi n, por falta de espacio o por inactividad, seg n se configure.

Activar Shared PC nicamente en equipos compartidos; nunca en los port tiles personales del profesorado.

Restringir el almacenamiento local cuando el trabajo deba guardarse en el servicio autorizado.

Eliminar perfiles de invitados al cerrar sesi n y probar antes la recuperaci n de archivos no guardados.

Dejar los equipos en suspensi n y no apagados: el mantenimiento autom tico se ejecuta cuando el equipo est en reposo.

Mantener una cuenta t cnica excluida de la eliminaci n y documentar esa excepci n.

Probar la configuraci n local o mediante GPO en un grupo piloto antes de extenderla.

4 Datos, accesos y recuperaci n

4.1 Acceso m nimo y clasificaci n de la informaci n

Cada persona debe acceder solo a la informaci n necesaria para su funci n. Los informes m dicos, psicopedag gicos y de orientaci n requieren un control especialmente estricto. Para clasificar los documentos antes de compartirlos se propone un modelo de cuatro niveles:

P blico	Informaci n aprobada para la web o la comunicaci n externa.	**Sin restricci n.**
Interno	Documentaci n de trabajo sin datos especialmente sensibles.	**Solo cuentas del centro.**
Confidencial	Actas, evaluaciones, informaci n de familias y documentos de gesti n.	**Carpetas por funci n; sin compartici n fuera del dominio.**
Restringido	Informes de orientaci n, salud y necesidades educativas.	**Acceso nominal, cifrado cuando proceda y registro de accesos.**

LA CLASIFICACI N SOLO SIRVE SI TIENE CONSECUENCIAS REALES

Control de acceso, cifrado, marca visible, bloqueo de compartici n o alerta. En Google Workspace, comprobar en la consola si la edici n contratada ofrece etiquetas, reglas de compartici n, prevenci n de p rdida de datos y auditor a; si no, aplicar la consecuencia mediante carpetas por funci n y restricci n de la compartici n externa. No afirmar que una etiqueta protege un archivo descargado si no incorpora cifrado o una regla que lo impida.

Limitar las carpetas por funci n: direcci n, tutor a, orientaci n, secretar a y departamentos.

Cifrar los port tiles que salgan del centro y proteger los soportes externos.

No guardar expedientes en equipos compartidos ni en nubes no autorizadas.

Borrar descargas temporales y cerrar sesi n tras imprimir o proyectar.

Revisar con el responsable del tratamiento y el DPD los proveedores, contratos y aplicaciones educativas que traten datos del alumnado, y mantener actualizado el Registro de Actividades de Tratamiento (RAT).

4.2 Revisi n peri dica de accesos

La revisi n no debe limitarse a eliminar las cuentas de quienes dejan el centro: tambi n debe comprobar si cada usuario conserva el acceso correcto a cada grupo, aplicaci n, carpeta y rol. Las bajas se tramitan de inmediato; el resto de la revisi n es trimestral (mensual en las cuentas con privilegios).

1. Exportar los miembros de grupos y las cuentas con privilegios desde la consola de administraci n.
2. Pedir al responsable de cada rea que confirme qui n necesita continuar.
3. Eliminar los accesos no confirmados, documentar las excepciones y conservar la fecha de revisi n.
4. Revisar de forma espec fica invitados, cuentas de sustituci n, antiguos grupos de clase y proveedores.

El registro lo mantiene la coordinaci n TIC.

4.3 Mapa de datos

Crear un mapa que indique qu datos se guardan, d nde, qui n accede, qu copia existe y cu ndo se eliminan. Se elabora junto con el RAT y sirve de base para la clasificaci n del apartado 4.1 y para evaluar cualquier brecha.

4.4 Copias y restauraci n

CISA recomienda mantener copias separadas de la red operativa, probar su recuperaci n de forma peri dica y que la direcci n revise la evidencia de esas pruebas. Se propone aplicar la regla **3-2-1**, habitual en el sector:

3	2	1
copias de los datos	**soportes o entornos distintos**	**copia fuera del centro**

Prueba de restauraci n

1. Seleccionar un conjunto representativo sin sobrescribir el original.
2. Registrar origen, fecha, tama o y responsable.
3. Restaurar en un entorno separado.
4. Comprobar legibilidad, permisos, versiones y dependencias.
5. Anotar tiempo, errores y correcciones.

Proteger las copias con una cuenta distinta de la administraci n ordinaria.

Conservar al menos una copia desconectada o con retenci n protegida.

Comprobar que la restauraci n conserva los permisos y no solo los archivos.

Definir qu servicios se recuperan primero para mantener la actividad del centro.

No dar por hecho que la nube sustituye a la copia: comprobar la papelera, la retenci n y los plazos de recuperaci n del servicio que se utilice.

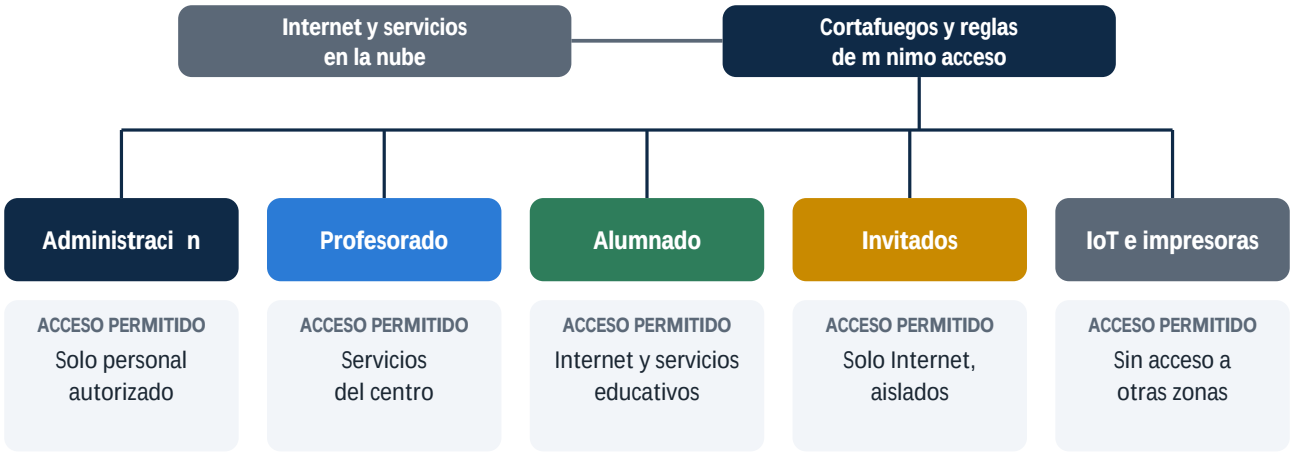
4.5 Brechas de datos personales

La AEPD indica que una brecha debe notificarse sin dilaci n indebida y, a ser posible, dentro de las 72 horas siguientes a que el responsable tenga constancia, salvo que sea improbable que suponga un riesgo para los derechos y libertades de las personas. No toda aver a es una brecha notificable: debe evaluarse, documentarse en la ficha del Anexo B y coordinarse con el DPD.

5 Red, dispositivos, correo y personas

5.1 Red y dispositivos

Una red plana permite que un equipo de alumnado o invitado alcance sistemas reservados a administraci n. Si la infraestructura y la autorizaci n lo permiten, separar administraci n, profesorado, alumnado, invitados e IoT mediante VLAN o SSID y reglas de m nimo acceso. El esquema siguiente es el objetivo de dise o, no el estado actual.



Usar WPA2 o WPA3 y desactivar WPS.

Cambiar las credenciales de administraci n de red por defecto.

Inventariar port tiles, puntos de acceso, switches, impresoras y dispositivos IoT (plantilla en el Anexo C).

Mantener firmware y sistemas actualizados, priorizando los parches de vulnerabilidades explotadas conocidas (cat logo KEV de CISA).

Mantener antivirus o EDR administrado en los equipos compatibles.

5.2 Correo y phishing

El centro debe contar con filtros y con un procedimiento visible para reportar correos sospechosos. SPF, DKIM y DMARC se configurar n nicamente en dominios que el centro controle (por ejemplo, iesmanueldefalla.com, una vez confirmada su administraci n), empezando por la monitorizaci n. Cualquier cambio relativo a EducaMadrid se coordina con su administraci n t cnica.

5.3 Dispositivos m viles y trabajo desde casa

Separar el rea personal del rea de trabajo.

Mantener actualizados el sistema y el antivirus.

No almacenar datos del alumnado en m viles personales sin autorizaci n.

Usar redes dom sticas protegidas y evitar la Wi-Fi p blica para informaci n sensible.

Comunicar de inmediato la p rdida de un port til, m vil o USB.

5.4 Uso de inteligencia artificial generativa

No se deben introducir datos identificables, expedientes, ex menes ni informes en herramientas no autorizadas. La direcci n, con el DPD, aprobar qu herramientas pueden usarse y para qu fines.

Ante la duda, no usar la herramienta o anonimizar antes el contenido.

Las aplicaciones aprobadas se revisan como cualquier otro proveedor (apartado 4.1).

La pol tica se comunica en la formaci n de inicio de curso y en cada incorporaci n.

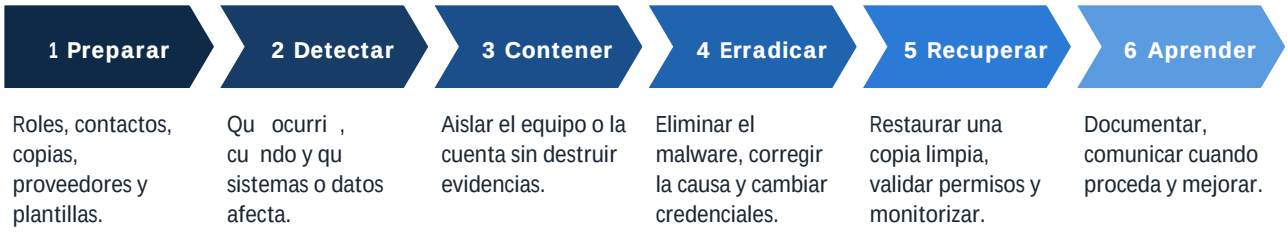
5.5 Formaci n

Inicio de curso	Bloqueo, cierre de sesi n, datos, phishing, IA generativa y reporte de incidencias.
Cada trimestre	Sesi n breve sobre una amenaza concreta.
Una vez al a o	Simulacro de phishing no punitivo.
En cada incorporaci n	Cuenta, permisos, uso aceptable e incidentes.
Ante la duda	No hacer clic, no responder y reportar.

6 Incidentes y continuidad

6.1 Procedimiento

El procedimiento debe estar impreso y disponible aunque la red no funcione. CISA recomienda redactar y ejercitar con regularidad un plan de respuesta por escrito, con responsables y una agenda de contactos sin conexi n, aprobado por un alto responsable (aqu , la direcci n) y revisado cada trimestre y tras cada incidente o casi incidente.



6.2 Primeras acciones

No borrar evidencias.

Aislar el equipo de la red si es seguro; no apagarlo salvo indicaci n t cnica.

Avisar a la coordinaci n TIC y a la direcci n, y anotar la hora.

No negociar ni pagar.

Activar al DPD si puede haber datos personales.

6.3 Clasificaci n de la gravedad

NIVEL	CRITERIO	RESPUESTA	AVISAR A
Baja	Incidencia aislada sin datos personales ni p rdida de servicio (por ejemplo, un phishing recibido y no abierto).	Registrar y resolver.	Coordinaci n TIC
Media	Cuenta o equipo comprometido sin indicios de acceso a datos sensibles, o servicio degradado.	Contener, cambiar credenciales y revisar la actividad.	Coordinaci n TIC y direcci n
Alta	Posible acceso a datos personales, ransomware en un equipo o p rdida de un dispositivo con datos.	Aislar, activar al DPD y evaluar la brecha (plazo de 72 horas).	Direcci n, TIC y DPD
Cr tica	Ransomware extendido, interrupci n prolongada del servicio educativo o brecha con datos sensibles del alumnado.	Activar el plan completo, restaurar y comunicar seg n proceda.	Direcci n, TIC, DPD y organismos competentes

Escala orientativa propuesta; debe aprobarse con la direcci n y el DPD.

6.4 Detecci n con se uelos (honeytoken)

La propuesta para el instituto es un honeytoken o se uelo, no un honeypot completo. CISA, en su gu a sobre cyber decoys (septiembre de 2026), define el honeytoken como un dato u objeto sin uso leg timo (registros, credenciales o archivos falsos): cualquier interacci n con l sugiere actividad no autorizada. Un honeypot es un sistema o servicio falso m s completo.

Crear un archivo ficticio, por ejemplo Presupuesto_Proyecto_2026.xlsx , sin datos reales ni credenciales v lidas.

Colocarlo en una ubicaci n que el personal leg timo no necesite abrir.

Generar una alerta cuando se abra, copie o autentique la cuenta se uelo.

Aislar el se uelo de los sistemas reales; no usarlo para atraer atacantes a datos del alumnado ni plantar contrase as falsas que puedan reutilizarse en sistemas reales.

Limitar qui n conoce la ubicaci n del se uelo para evitar falsas alarmas, y activar el procedimiento de incidentes cuando salte la alerta.

CONDICI N DE VIABILIDAD

La alerta exige una herramienta de auditor a o alertas, por ejemplo el registro de actividad de Drive en la consola de Google Workspace, si la edici n contratada lo permite. Si no hay herramienta que genere la alerta, la medida no es viable y no debe implantarse. El DPD valida la monitorizaci n antes de activarla.

6.5 Continuidad y revocaci n r pida

Realizar una prueba anual de ca da de Internet y de EducaMadrid con procedimientos en papel.

Mantener impresos el plan de incidentes y la agenda de contactos (Anexo A), con un contacto fuera de la red.

Ante la p rdida de un m vil, port til o credencial: avisar a TIC, cambiar la contrase a, cerrar las sesiones activas desde la consola de administraci n, revocar las llaves de seguridad perdidas y revisar la actividad reciente de la cuenta.

7 Plan de acci n

Calendario de implantaci n por prioridad, responsable y dependencia. Los plazos cuentan desde la aprobaci n del plan. La ltima columna es para marcar las medidas completadas.

N.	MEDIDA	PRIORIDAD	RESPONSABLE	PLAZO	DEPENDE DE	HECHO
PRIMER MES Base y medidas de mayor riesgo						
1	Confirmar plataformas y administradores (Google Workspace, EducaMadrid, red).	Alta	D. Navarro	Mes 1	Direcci n	☐
2	Inventario de equipos, cuentas y servicios (Anexo C).	Alta	D. Navarro	Mes 1		☐
3	Revisar cuentas privilegiadas y bajas de personal.	Alta	D. Navarro	Mes 1		☐
4	Imprimir el plan de incidentes y la agenda de contactos (Anexos A y B).	Alta	D. Navarro	Mes 1	Direcci n y DPD	☐
5	Diagn stico de copias y primera copia verificada.	Alta	D. Navarro	Mes 1	Medida 1	☐
6	MFA en administradores y direcci n, si el servicio lo permite.	Alta	D. Navarro	Mes 1	Medida 1	☐
7	Piloto de bloqueo autom tico: un aula (600 s) y un despacho (900 s).	Media	D. Navarro	Mes 1		☐
8	Formaci n de inicio de curso, incluida la pol tica de IA.	Media		Mes 1	Direcci n	☐
MESES 2 Y 3 Control de datos y recuperaci n						
9	Revisi n de permisos y carpetas por funci n.	Alta	D. Navarro	Meses 2 3	Responsables de rea	☐
10	Primera restauraci n completa de prueba.	Alta	D. Navarro	Meses 2 3	Medida 5	☐
11	Protecci n de las copias: cuenta distinta y copia desconectada.	Alta	D. Navarro	Meses 2 3	Medida 5	☐
12	Mapa de datos y revisi n del RAT, aplicaciones y proveedores.	Media		Meses 2 3	DPD	☐
13	Pol tica de IA generativa aprobada y comunicada.	Media		Meses 2 3	Direcci n y DPD	☐
14	Dise o de la segmentaci n de red.	Media	D. Navarro	Meses 2 3	Medida 2	☐

N.	MEDIDA	PRIORIDAD	RESPONSABLE	PLAZO	DEPENDE DE	HECHO
15	Primer simulacro de phishing no punitivo.	Media	D. Navarro	Meses 2 3	Medida 8	☐
MESES 4 A 6 Ampliaci n y endurecimiento						
16	Extender el bloqueo y el cierre de sesi n a todas las aulas; aula segura en puestos compartidos.	Media	D. Navarro	Meses 4 6	Resultado de la medida 7	☐
17	Segmentaci n de red, si procede.	Media	D. Navarro	Meses 4 6	Medida 14 y autorizaci n	☐
18	SPF, DKIM y DMARC en los dominios controlados.	Media	D. Navarro	Meses 4 6	Control del DNS	☐
19	MDM o EDR administrado en los equipos compatibles.	Media	D. Navarro	Meses 4 6	Licencias y presupuesto	☐
20	Llaves FIDO2 en cuentas cr ticas.	Media	D. Navarro	Meses 4 6	Soporte confirmado	☐
21	Ejercicio de incidente y prueba de ca da de Internet.	Media	D. Navarro	Meses 4 6	Medida 4	☐
22	Se uelo (honeytoken), si existe herramienta de alerta.	Baja	D. Navarro	Meses 4 6	Herramienta y DPD	☐

D. Navarro: Diego Navarro, Coordinaci n TIC. Las celdas de responsable vac as se completar n cuando se designen.

8 Glosario, fuentes y aprobaci n

8.1 Glosario de siglas y t rminos

DPD	Delegado de Protecci n de Datos.
RAT	Registro de Actividades de Tratamiento: inventario de los tratamientos de datos personales del centro.
ENS	Esquema Nacional de Seguridad: marco de seguridad del sector p blico espa ol.
MFA	Autenticaci n multifactor: adem s de la contrase a, un segundo factor (aplicaci n, SMS o llave).
FIDO2 / passkey	Est ndar de autenticaci n con llave f sica o dispositivo, resistente al phishing.
GPO	Directiva de grupo de Windows: configura de forma centralizada los equipos de un dominio.
MDM	Gesti n de dispositivos desde una consola central (instalar, configurar, bloquear y borrar).
EDR	Antivirus avanzado que detecta, registra y ayuda a responder a amenazas en cada equipo.
DLP	Prevenci n de p rdida de datos: reglas que impiden compartir o sacar informaci n sensible.
VLAN / SSID	Redes virtuales o Wi-Fi separadas dentro de la misma infraestructura.
KEV	Cat logo de CISA de vulnerabilidades que ya se est n explotando en ataques reales.
Ransomware	Programa malicioso que cifra los datos y exige un pago para devolverlos.
Honeytoken	Dato, archivo o cuenta falsos que generan una alerta cuando alguien los usa.

8.2 Fuentes consultadas

Centro, Comunidad de Madrid y normativa

Ficha oficial del centro https://gestiona.comunidad.madrid/wpad_pub/run/j/MostrarFichaCentro.icm?cdCentro=28028568

EducaMadrid https://www.comunidad.madrid/educacion/educamadrid

Comunidad de Madrid tratamiento y protecci n de datos en el mbito educativo (contacto del DPD) https://www.comunidad.madrid/servicios/educacion/tratamiento-proteccion-datos-ambito-educativo

AEPD Gu a para centros educativos https://www.aepd.es/guias/guia-centros-educativos.pdf

AEPD formulario de notificaci n de brechas https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/nuevo-formulario-notificacion-brechas-datos-personales

AEPD notificaci n de brechas de datos personales https://www.aepd.es/preguntas-frecuentes/2-tus-obligaciones-como-responsable-del-tratamiento/11-brechas-de-datos-personales/FAQ-0233-a-quien-hay-que-notificar-las-brechas-de-datos-personales

Reglamento (UE) 2016/679 (RGPD) https://eur-lex.europa.eu/eli/reg/2016/679/oj

Ley Org nica 3/2018 (LOPDGDD) https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673

Real Decreto 311/2022 (Esquema Nacional de Seguridad) https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191

INCIBE y CISA

INCIBE Ciberseguridad en el centro educativo https://www.incibe.es/menores/blog/ciberseguridad-en-el-centro-educativo

INCIBE Ciberseguridad en el sector educativo https://www.incibe.es/empresas/blog/ciberseguridad-en-el-sector-educativo

INCIBE L nea de Ayuda en Ciberseguridad (017) https://www.incibe.es/linea-de-ayuda-en-ciberseguridad/faq

CISA Online Toolkit for K-12 organizations https://www.cisa.gov/online-toolkit-partnering-safeguard-k-12-organizations-cybersecurity-threats

CISA Google Workspace Common Controls (SCuBA) https://www.cisa.gov/resources-tools/services/gws-commoncontrols

CISA Using Cyber Decoys to Strengthen Detection and Response https://www.cisa.gov/resources-tools/resources/using-cyber-decoys-strengthen-detection-and-response

CISA Implementing phishing-resistant MFA https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf

Google y Windows

Google duraci n de la sesi n de los servicios de Google https://knowledge.workspace.google.com/admin/security/set-session-length-for-google-services

Microsoft Interactive logon: Machine inactivity limit https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/security-policy-settings/interactive-logon-machine-inactivity-limit

DISA STIG WN11-SO-000070 (clave de registro de la directiva) https://stigaview.com/products/win11/v1r5/WN11-SO-000070

Microsoft Shared PC https://learn.microsoft.com/en-us/windows/configuration/shared-pc/shared-devices-concepts

8.3 Agradecimientos

Este proyecto se ha preparado para el IES Manuel de Falla de M stoles con agradecimiento a la Coordinaci n TIC del centro, especialmente a Diego Navarro, y a toda la comunidad educativa.

8.4 Aprobaci n

CARGO	NOMBRE	FIRMA
Direcci n		
Coordinaci n TIC	Diego Navarro	
Responsable del tratamiento o DPD		

9 Anexos

Anexo A Agenda de contactos (copia impresa)

FUNCI N	NOMBRE	TEL FONO	CORREO U OTRO MEDIO
Direcci n			
Coordinaci n TIC	Diego Navarro		
Secretar a			
Responsable del tratamiento			
DPD de la Consejer a de Educaci n		91 720 4068	protecciondatos.educacion@madrid.org
Administraci n de Google Workspace			
Soporte de EducaMadrid (CAU)			
Proveedor de red o inform tica			
INCIBE L nea de Ayuda en Ciberseguridad	Gratuita y confidencial	017	Todos los d as, de 8:00 a 23:00
AEPD notificaci n de brechas			Sede electr nica de la AEPD (sedeagpd.gob.es)
Emergencias		112	
Contacto fuera de la red (m vil)			

El tel fono y el correo del propio centro figuran en la portada.

Anexo B Ficha de incidente

CAMPO	DATOS
Fecha y hora de detecci n	
Persona que informa	
Sistema, cuenta o equipo afectado	
Descripci n de lo ocurrido	
Datos personales afectados?	S / No / No se sabe
Gravedad (apartado 6.3)	Baja / Media / Alta / Cr tica
Acciones de contenci n y hora	
Avisos realizados (TIC, direcci n, DPD)	
Evidencias conservadas	
Causa y erradicaci n	
Recuperaci n y validaci n	
Notificaci n a la AEPD (plazo de 72 h)	S / No Hora l mite:
Lecciones aprendidas y mejoras	

Anexo C Plantilla de inventario

Una fila por port til, punto de acceso, switch, impresora, dispositivo IoT, servicio y cuenta con privilegios.

ELEMENTO	TIPO	UBICACI N O RESPONSABLE	SISTEMA Y VERSI N	GESTI N	NOTAS

Anexo D Costes estimados

Precios de lista consultados en octubre de 2026 en las p ginas de los fabricantes y distribuidores enlazadas. Son orientativos: no incluyen descuentos educativos ni condiciones de compra p blica y deben confirmarse con un presupuesto. La columna IVA indica si el precio publicado ya lo incluye. Las cantidades en d lares no se han convertido a euros.

Licencias y software

CONCEPTO	PRECIO	IVA	VALORACI N	FUENTE
Google Workspace for Education Fundamentals	0		Imprescindible; ya en uso	google.com
Google Education Plus	6 $ por usuario (periodo por confirmar)		Opcional, solo para direcci n y administraci n	google.com
Teaching and Learning Upgrade	60 $ por usuario y a o; 6 $ al mes en plan flexible		Opcional	google.com
Bitwarden Free / Teams	0 / 4 $ por usuario y mes (facturaci n anual)		Free basta para empezar	bitwarden.com
Wazuh (monitorizaci n)	0 (c digo abierto)		Gratis; requiere tiempo del equipo TIC	wazuh.com
Microsoft Defender for Business	3 $ por usuario y mes; hasta 300 usuarios		Mejor calidad-precio si hay Windows; dato de una gu a de terceros	casrai.org
ESET Protect Entry	42,20 $ por equipo y a o (unos 29,50 $ con 50 equipos o m s)		Alternativa de pago; dato de un comparador	costbench.com
Bitdefender GravityZone Small Business	57 $ por equipo y a o		M s caro que ESET; dato de un comparador	costbench.com
Copia de Google Workspace (Backupify / Spanning)	3 $ / 4 $ por usuario y mes (lista de 2021); en educaci n, hasta 2 3 veces menos		Pedir presupuesto; dato antiguo	afi.ai

Llaves de seguridad FIDO2

CONCEPTO	PRECIO	IVA	VALORACI N	FUENTE
YubiKey 5 NFC / 5C NFC	70,18	Incluido	Recomendada: la m s vendida	yubico.com
YubiKey 5C	78,65	Incluido	Solo si hace falta otro formato	yubico.com
YubiKey 5 Nano / 5C Nano	82,28	Incluido	Para dejar en el puerto del equipo	yubico.com
Google Titan	45 55 (precio de 2020)	Incluido	Comprobar el precio actual	clubic.com

Copias de seguridad, servidores y energ a

CONCEPTO	PRECIO	IVA	VALORACI N	FUENTE
Synology DS425+ (NAS de 4 bah as, sin discos)	554,99 (unos 671,54 con IVA del 21 %)	No incluido	Buena opci n para la copia local	bechtle.com
Discos duros para NAS	Sin precio verificado		Presupuestar aparte (4 discos)	
SAI APC Back-UPS 1200 VA	205,95	Incluido	Protege el NAS ante cortes de luz	ldlc.com
Hetzner Storage Box BX11 (1 TB) / BX21 (5 TB)	3,20 / 10,90 al mes (dato de 2025)	Por confirmar	Mejor calidad-precio para la copia externa; servidores en Alemania o Finlandia	hetzner.com
Backblaze B2	6,95 $ por TB y mes (5 TB, unos 417 $ al a o)		Opci n en la nube; inmutabilidad por confirmar	backblaze.com
Wasabi	7,99 $ por TB y mes (5 TB, unos 479,40 $ al a o)		Sin cargos por descarga	wasabi.com

Red y seguridad perimetral

CONCEPTO	PRECIO	IVA	VALORACI N	FUENTE
Switch UniFi Lite 8 PoE / Lite 16 PoE	99 / 179	Por confirmar	Para aulas o armarios peque os	ui.com
Switch UniFi 24 PoE / Pro 24 PoE	340 / 629	Por confirmar	El de 340 basta para segmentar la red	ui.com
Punto de acceso U6 Plus / U6 Pro / U7 Pro	89 / 145 / desde 160	Por confirmar	U6 Plus cubre la mayor a de aulas	ui.com
FortiGate-40F con servicios, 1 a o	1.180,42 (unos 1.428,31 con IVA del 21 %); se renueva cada a o	No incluido	Solo si no hay quien configure un firewall libre	software-express.de
Netgate 2100 (pfSense+)	599 $; soporte de 399 a 799 $ al a o		Alternativa al FortiGate	netgate.com

Tres escenarios de ejemplo

M nimo

757,83

Primer a o; despu s, unos 130,80 anuales de copia externa.

INCLUYE

6 llaves YubiKey 5 NFC (421,08), Hetzner de 5 TB (130,80 al a o) y SAI (205,95). Google, Bitwarden Free y Wazuh sin coste.

Recomendado

1.769,37

Primer a o, sin discos, m s 1.440 $ al a o de antivirus.

SUMA AL M NIMO

NAS DS425+ (671,54), un switch UniFi 24 PoE (340) y Defender para 40 puestos (40 3 $ 12 meses).

Completo

4.265,68

Primer a o, sin discos, m s 1.440 $ al a o de antivirus.

SUMA AL RECOMENDADO

FortiGate-40F con servicios (1.428,31) y 12 puntos de acceso U6 Plus (1.068). Copia de Workspace por presupuesto.

Supuestos del ejemplo: 6 llaves, 12 puntos de acceso y 40 puestos con antivirus; el n mero real de alumnos, aulas y equipos cambia el total. Los precios de UniFi y Hetzner no confirman si incluyen IVA. Todas las cifras se han sumado a partir de los precios de las tablas.